COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · Password Attacks

Mestre CyberSec · **Aula 2.4 — Password Attacks** (7:15) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Password attack: password spraying (UMA senha comum MUITOS usuários — evita lockout); credential stuffing (senhas VAZADAS reusadas); brute force (todas as combinações — rápido mas detectável); dictionary (lista de palavras); rainbow table (hash pré-computados — MORTO pelo SALTING

💡 Highlights que a prova CompTIA cobra

- Password spraying: 1 senha fraca contra muitos usuários (discreto)
- Brute force = tentar tudo; dictionary = lista de palavras
- Rainbow table = hash pré-computada — MORTA pelo SALTING
- Reusa de senha vazada em outros sites = credential stuffing

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'single weak password tried against many accounts' = password spraying
- 'pre-computed hash table' = rainbow table (defesa: salting)

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — Password Attacks)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Pulverização de Senhas (N/A)

Ataque que tenta uma única senha fraca comum contra muitas contas de usuário diferentes, muitas vezes respeitando limites para evitar bloqueio de conta.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'uma senha fraca contra muitas contas' = password spraying. Não confunda com brute force/dictionary, que focam uma única conta.*

• Preenchimento de Credenciais (N/A)

Uso de pares usuário/senha vazados de um serviço para autenticar em outros serviços, explorando a reutilização de senha.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'senhas vazadas reutilizadas em outros sites' = credential stuffing; difere de spraying porque usa pares usuário/senha vazados.*

• Ataque de Força Bruta (N/A)

Tentar todas as combinações possíveis de caracteres até encontrar a senha correta; pode ser online ou offline.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'todas as combinações possíveis'. É barulhento/detectável online e pode causar lockout.*

• Ataque de Dicionário (N/A)

Uso de uma lista de palavras comuns, senhas vazadas e variações para adivinhar senhas, em vez de tentar todas as combinações possíveis.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'lista de palavras' ou 'wordlist'. Não tenta todas as combinações como o brute force.*

• Tabela Arco-Íris (N/A)

Tabela pré-computada de hashes de senhas usada para reverter rapidamente hashes de senhas sem sal.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'tabela de hashes pré-computados' = rainbow table; defesa principal: salting.*

• Salting (N/A)

Adicionar um valor aleatório único a cada senha antes do hash, armazenado junto ao hash, para que senhas iguais produzam hashes diferentes.

⚠️ ***Armadilha CompTIA:*** *Gatilho: salting torna rainbow tables inúteis. Não impede brute force, mas aumenta o custo; senhas iguais geram hashes diferentes.*

• Hash de Senha (N/A)

Representação criptográfica unidirecional de uma senha usada para verificação; se roubada, pode ser atacada offline.

⚠️ ***Armadilha CompTIA:*** *Gatilho: hash não é criptografia; ataques offline usam hashes roubados. Salting e key stretching são defesas.*

• Alongamento de Chave (N/A)

Aplicar hashing repetido e salgado para tornar a verificação de senha mais lenta e encarecer ataques de força bruta ou dicionário.

⚠️ ***Armadilha CompTIA:*** *Gatilho: bcrypt, PBKDF2, Argon2 = key stretching. Defesa contra brute force/dicionário, especialmente offline.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Ataque de Repetição (Replay Attack)

🏠 **Analogia Intuitiva:** Imagine o controle remoto de um carro de luxo. Quando o dono aperta o botão para abrir a porta, o controle emite um sinal de rádio. Um criminoso escondido usa um gravador de áudio e captura exatamente aquela frequência. Mais tarde, no meio da noite, o criminoso vai até o carro e aperta 'play' no gravador. O carro ouve o sinal original gravado e destranca a porta, pois não sabe diferenciar a emissão ao vivo de uma fita reproduzida.

🔍 **Causa Raiz / Por que foi criado:** Protocolos de autenticação que validam apenas a credencial ou o hash da mensagem, mas ignoram a novidade (freshness) e o carimbo de tempo da transação. O atacante não precisa quebrar a criptografia nem saber a senha; basta retransmitir os pacotes gravados.

🛡️ **Visão do Auditor de GRC:** Auditar sistemas bancários, APIs de pagamentos e mecanismos de autenticação legado contra repetição; exigir rejeição compulsória de pacotes duplicados e uso de tokens criptográficos não reutilizáveis.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'attacker intercepts valid authentication tokens or network packets and retransmits them later to gain unauthorized access without decrypting the payload'. Resposta: Replay Attack.

📌 Nonce Criptográfico (Number Used Once)

🏠 **Analogia Intuitiva:** É como um banco distribuir senhas de atendimento numeradas: 001, 002, 003. Quando você entrega a senha 001 no caixa, o atendente rasga e joga o papel no triturador. Se um golpista achar pedaços da senha 001 ou tirar foto dela e tentar usá-la dez minutos depois, o atendente diz: 'Esta senha já foi consumida e não vale mais nada!'. O nonce é um número gerado aleatoriamente que só é aceito uma única vez.

🔍 **Causa Raiz / Por que foi criado:** Para invalidar gravações de rede, o servidor gera e envia ao cliente um valor imprevisível e efêmero. O cliente precisa assinar esse valor na sua resposta; o servidor confere se aquele nonce já foi utilizado e descarta qualquer requisição repetida.

🛡️ **Visão do Auditor de GRC:** Revisar especificações de APIs corporativas e webhooks; garantir que parâmetros de nonce e hash de validação estejam presentes em todas as transações sensíveis de transferência de dados.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'random or pseudorandom number issued in an authentication protocol to ensure that old communications cannot be reused in replay attacks'. Resposta: Nonce (Number Used Once).

📌 Carimbos de Data/Hora e Janelas de Tempo (Timestamping & Kerberos)

🏠 **Analogia Intuitiva:** É como um ingresso de cinema com data e hora exata: 'Válido exclusivamente para 21 de Outubro às 19h00'. Se alguém tentar entrar na sessão do cinema com esse ingresso no dia seguinte ou na semana que vem, o porteiro recusa na hora porque a janela de validade expirou. No protocolo Kerberos, computadores cujos relógios internos estejam desfasados por mais de 5 minutos não conseguem conversar.

🔍 **Causa Raiz / Por que foi criado:** Ao atrelar a validade da mensagem a um carimbo de data/hora sincronizado, a janela de oportunidade para um invasor capturar e retransmitir o pacote fica restrita a poucos segundos ou minutos. Pacotes com timestamps fora da janela de tolerância (time skew) são sumariamente descartados.

🛡️ **Visão do Auditor de GRC:** Auditar a infraestrutura de sincronização de relógios corporativos (NTP seguro); assegurar que servidores e estações Active Directory mantenham sincronia estrita (máximo de 5 minutos de desvio no Kerberos) para evitar falhas de autenticação.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho: 'authentication protocol relies on synchronized system time and rejects tickets exceeding a maximum allowable time skew (typically 5 minutes) to defeat replay attacks'. Resposta: Kerberos / Timestamps.

📌 Identificadores e Tokens de Sessão Efêmeros (Unique Session IDs)

🏠 **Analogia Intuitiva:** É como a pulseira de papel colocada no seu pulso em um festival de música que se rasga e se destrói se você tentar retirá-la para passar a outra pessoa. Além disso, a cada nova compra feita no bar do evento, a pulseira é carimbada com uma marca diferente. Se alguém tentar usar uma foto da pulseira antiga, o sistema recusa.

🔍 **Causa Raiz / Por que foi criado:** Aplicações web que mantêm identificadores de sessão estáticos ou com tempo de vida infinito facilitam o sequestro de sessão (Session Hijacking). O uso de IDs de sessão randômicos, criptograficamente seguros e rotacionados após o login neutraliza o reuso de credenciais.

🛡️ **Visão do Auditor de GRC:** Fiscalizar parâmetros de cookies de autenticação em aplicações web: verificar uso compulsório dos atributos `Secure`, `HttpOnly` e `SameSite=Strict`, além de tempo de expiração curto para sessões inativas.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho: 'countermeasure that regenerates a new session identifier upon successful user login to thwart session replay and fixation'. Resposta: Session ID Rotation / Ephemeral Session Tokens.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Captura e retransmissão não autorizada de pacotes ou credenciais válidas para obter acesso indevido	**Ataque de Repetição (Replay Attack)**
Valor numérico aleatório de uso único incluído em mensagens para impedir retransmissões antigas	**Nonce (Number Used Once)**
Mecanismo no protocolo Kerberos que descarta pacotes antigos com base no relógio sincronizado	**Carimbo de Data/Hora (Timestamping & Time Skew de 5 min)**
Serviço de rede que precisa ser mantido seguro e sincronizado para garantir a integridade de autenticações	**NTP (Network Time Protocol)**
Prática de gerar um novo identificador exclusivo logo após a autenticação do usuário	**Rotação de ID de Sessão (Session ID Rotation)**
Ataque em que o invasor rouba um cookie de sessão ativo para navegar fingindo ser o usuário legítimo	**Sequestro de Sessão (Session Hijacking)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de segurança vê logs de autenticação em que um único IP de origem tentou a senha Summer2024! contra 300 contas de usuário diferentes. Cada conta recebeu apenas um login com falha, e nenhuma conta foi bloqueada. As tentativas continuaram a cada 45 minutos com uma senha comum diferente. Qual ataque de senha melhor corresponde a esse comportamento?

A) Credential stuffing usando credenciais de um vazamento de terceiros

B) Password spraying para evitar limites de bloqueio de conta

C) Ataque de força bruta offline contra hashes de senha capturados

D) Consulta de rainbow table contra hashes de senha sem salt

QUESTÃO 2 · CENÁRIO DE EXAME

Funcionários de uma empresa relatam logins VPN não autorizados de locais desconhecidos. A investiga��ão mostra que o atacante usou uma lista de endereços de e-mail e senhas obtidas de um vazamento não relacionado em uma rede social. Alguns logins tiveram sucesso porque os funcionários reutilizaram suas senhas pessoais no trabalho. Qual ataque ocorreu?

A) Ataque de dicionário

B) Password spraying

C) Credential stuffing

D) Ataque de força bruta

QUESTÃO 3 · CENÁRIO DE EXAME

Um testador de penetração extrai hashes de senha de um aplicativo legado que usa MD5 sem salt. Em vez de enviar tentativas de login, o testador usa um mapeamento pré-computado muito grande de valores de hash para senhas em texto claro e recupera várias senhas rapidamente. Qual técnica está sendo usada?

A) Ataque de rainbow table

B) Password spraying

C) Key stretching

D) Credential stuffing

QUESTÃO 4 · CENÁRIO DE EXAME

Um desenvolvedor está atualizando o armazenamento de senhas de um aplicativo. A equipe de segurança quer garantir que dois usuários que escolherem a mesma senha não produzam o mesmo hash armazenado, e que tabelas de consulta pré-computadas não possam ser reutilizadas contra o banco de dados. Qual mudança o desenvolvedor deve implementar?

A) Aplicar uma política de expiração de senha a cada 90 dias

B) Exigir autenticação multifator para todos os usuários

C) Configurar bloqueio de conta após três tentativas falhas

D) Adicionar um valor aleatório único a cada senha antes de gerar o hash

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa precisa armazenar hashes de senha para um aplicativo interno de alto valor. O arquiteto de segurança quer que o processo de hash permaneça lento e exigente em recursos mesmo em hardware moderno, para que a adivinhação offline de cada senha leve muito mais tempo. Qual técnica deve ser selecionada?

A) Key stretching com bcrypt ou PBKDF2

B) Prevenção de password spraying

C) Detecção de credential stuffing

D) Geração de rainbow table

QUESTÃO 6 · CENÁRIO DE EXAME

Um atacante captura um banco de dados de hashes de senha de um servidor e então usa uma ferramenta que testa sistematicamente todas as combinações possíveis de letras, números e símbolos até encontrar o texto claro correto para uma conta de administrador. Que tipo de ataque é este?

A) Ataque de dicionário

B) Credential stuffing

C) Ataque de força bruta

D) Password spraying

QUESTÃO 7 · CENÁRIO DE EXAME

Durante uma avaliação de aplicativo web, um testador usa uma lista contendo senhas comuns, estações do ano e variações do nome da empresa para adivinhar senhas de usuários. O testador testa a lista contra um único nome de usuário conhecido até encontrar uma correspondência. Qual ataque está sendo realizado?

A) Ataque de rainbow table

B) Ataque de dicionário

C) Ataque de força bruta

D) Password spraying

QUESTÃO 8 · CENÁRIO DE EXAME

Uma empresa de serviços financeiros permite que usuários se autentiquem em um portal interno. Atacantes tentam repetidamente uma senha comum em muitas contas de funcionários, esperando entre as tentativas para que cada conta permaneça abaixo do limite de bloqueio. Qual controle mitiga mais diretamente esse ataque específico sem depender apenas do bloqueio de conta?

A) Autenticação multifator

B) Aumentar o comprimento máximo da senha

C) Desativar o histórico de senhas

D) Armazenar senhas com criptografia reversível

QUESTÃO 9 · CENÁRIO DE EXAME

Uma organização descobre que várias contas de usuário foram comprometidas porque funcionários usaram as mesmas senhas em sistemas corporativos e sites pessoais que depois foram vazados. Os atacantes simplesmente reutilizaram os pares de nome de usuário e senha vazados. Qual controle adicional impediria melhor que isso tivesse sucesso no futuro?

A) Requisitos de complexidade de senha

B) Intervalos mais curtos de expiração de senha

C) Autenticação multifator

D) Salts únicos no banco de dados de hashes de senha

QUESTÃO 10 · CENÁRIO DE EXAME

Um auditor de segurança descobre que um banco de dados armazena hashes de senha SHA-256 sem salt. O auditor alerta que atacantes poderiam recuperar muitas senhas de uma vez se o banco de dados fosse roubado. Qual ataque de senha é mais diretamente mitigado ao adicionar um salt único a cada senha antes de gerar o hash?

A) Password spraying

B) Credential stuffing

C) Ataque de dicionário

D) Ataque de rainbow table

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Password spraying para evitar limites de bloqueio de conta

Correto: password spraying tenta poucas senhas comuns em muitas contas para permanecer abaixo dos limites de bloqueio. O cenário mostra uma tentativa por conta em 300 contas, com senhas comuns repetidas, não pares de credenciais vazadas, força bruta por conta ou busca offline de hashes. Credential stuffing usaria pares usuário/senha vazados; brute force faria muitas tentativas por conta; rainbow table é um ataque offline com hashes pré-computados.

Questão 2: Alternativa C — Credential stuffing

Correto: credential stuffing usa pares de usuário e senha roubados de outros vazamentos e os reutiliza contra o alvo, contando com a reutilização de senhas. O cenário envolve um vazamento não relacionado e logins bem-sucedidos por senhas reutilizadas. Password spraying usa senhas comuns em muitas contas; dictionary usa listas de palavras; brute force testa todas as combinações.

Questão 3: Alternativa A — Ataque de rainbow table

Correto: uma rainbow table é um mapeamento pré-computado de hashes para senhas em texto claro, eficaz contra hashes sem salt. Salting ou key stretching com salts únicos derrotam tabelas pré-computadas. Password spraying e credential stuffing são ataques de credenciais online, não buscas offline em hashes pré-computados.

Questão 4: Alternativa D — Adicionar um valor aleatório único a cada senha antes de gerar o hash

Correto: salting adiciona dados aleatórios únicos a cada senha antes do hash, então senhas iguais produzem hashes diferentes e tabelas pré-computadas não podem ser reutilizadas. Expiração de senha, MFA e bloqueio de conta são controles úteis, mas não alteram a unicidade do hash nem impedem o reuso de rainbow tables contra hashes roubados.

Questão 5: Alternativa A — Key stretching com bcrypt ou PBKDF2

Correto: key stretching, como bcrypt, PBKDF2 ou Argon2, torna o hash intencionalmente lento com iterações ou fatores de trabalho, encarecendo a adivinhação offline. Password spraying e credential stuffing são métodos de ataque, não defesas. Geração de rainbow table é ataque; salting sozinho evita pré-computação, mas key stretching adiciona custo computacional.

Questão 6: Alternativa C — Ataque de força bruta

Correto: brute force testa sistematicamente todas as combinações possíveis, podendo encontrar senhas curtas ou fracas, mas é lento e ruidoso. Dictionary usa uma lista focada de palavras; credential stuffing reutiliza pares vazados; password spraying tenta poucas senhas comuns em muitas contas para evitar bloqueio.

Questão 7: Alternativa B — Ataque de dicionário

Correto: um ataque de dicionário usa uma lista curada de senhas prováveis e variações, geralmente mais rápido que brute force exaustivo contra senhas escolhidas por humanos. Rainbow tables exigem hashes capturados; brute force testa todas as combinações; password spraying ataca muitas contas com poucas senhas.

Questão 8: Alternativa A — Autenticação multifator

Correto: MFA mitiga mais diretamente o password spraying, pois mesmo que a senha comum seja adivinhada para uma conta, o atacante ainda precisa de um segundo fator. Comprimento e complexidade de senha podem ajudar, mas não impedem diretamente o padrão do ataque; histórico de senhas e criptografia reversível são controles ruins. Bloqueio de conta isolado pode ser contornado espalhando tentativas abaixo do limite em muitas contas.

Questão 9: Alternativa C — Autenticação multifator

Correto: MFA impede que credential stuffing tenha sucesso apenas com usuário e senha vazados, porque o atacante não consegue fornecer o segundo fator. Complexidade e expiração podem reduzir senhas fracas, mas não impedem a reutilização de credenciais válidas vazadas; salting protege hashes armazenados, não a autenticação online com credenciais vazadas válidas.

Questão 10: Alternativa D — Ataque de rainbow table

Correto: rainbow tables dependem de valores de hash pré-computados. Um salt único por senha altera a saída do hash, tornando tabelas pré-computadas ineficazes. Password spraying e credential stuffing são ataques online com credenciais adivinhadas ou vazadas; ataques de dicionário ainda podem tentar adivinhar, mas o salt especificamente derrota consultas pré-computadas.